Amazon S3: Study Notes

Buckets, security, versioning, storage classes, lifecycle rules and static website hosting

1. What S3 Is

S3 (Simple Storage Service) stores files as **objects** inside **buckets**. It is one of the most used AWS services: backups, website files, data lakes, logs and application storage all commonly live in S3.

Term	Meaning
Bucket	A container for objects. Created in one Region. The name must be **globally unique** across all AWS accounts (3 to 63 characters, lowercase letters, numbers and hyphens).
Object	A file plus its metadata. Identified by a **key** (the full path, such as `images/logo.png`). Up to **5 TB** each.
Key and prefix	S3 has no real folders. A "folder" is just a shared prefix in the key name; the console shows it as a folder.
Multi-part upload	Objects over 5 GB **must** be uploaded in parts. It is recommended above about 100 MB.
Consistency	S3 gives **strong read-after-write consistency**: after a successful write or delete, the next read shows the change.

2. Security: Who Can Access What

Everything in S3 is **private by default**. Access is controlled in layers:

Layer	What it does
IAM policy	Attached to a user, group or role. Says what that identity may do in S3.
Bucket policy	A JSON policy attached to the bucket (a *resource-based* policy). Can grant access to other accounts or to the public.
Block Public Access	A safety switch at bucket and account level. While it is on, public policies are blocked no matter what the policy says.
ACLs	Older per-object permissions. Disabled by default on new buckets ("bucket owner enforced"); prefer policies.
Encryption	New objects are encrypted at rest by default with **SSE-S3**. Other choices: SSE-KMS (keys you control in KMS), SSE-C (your own key), or client-side encryption.

How access is decided: a request is allowed if an IAM policy **or** the bucket policy allows it, and there is **no explicit Deny** anywhere. An explicit Deny always wins.

A public-read bucket policy (used in the static website lab)

```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Sid": "PublicReadForWebsite",
    "Effect": "Allow",
    "Principal": "*",
    "Action": "s3:GetObject",
    "Resource": "arn:aws:s3:::YOUR-BUCKET-NAME/*"
  }]
}
```

- **Principal "*"** means everyone. **s3:GetObject** lets them read files only, not list, upload or delete.

- **Resource ends with /*** because the permission applies to the *objects* inside the bucket, not the bucket itself.

3. Versioning

- A bucket-level setting. Once enabled, overwriting a file creates a **new version** instead of replacing it.
- Deleting a file adds a **delete marker**; the older versions are still there and can be restored by deleting the marker.
- Files uploaded before versioning was turned on get the version ID **null**.
- **Suspending** versioning does not delete existing versions. Old versions also cost storage, which is why lifecycle rules matter.
- Protects against accidental deletes and overwrites.

4. Storage Classes

All classes have **11 nines (99.999999999%) durability**. They differ in price, availability and how quickly you can retrieve data.

Class	Use for	Notes
Standard	Frequently accessed data	No minimum duration, no retrieval fee. The default.
Intelligent-Tiering	Unknown or changing access patterns	Moves objects between tiers automatically; small per-object monitoring fee.
Standard-IA	Infrequent access, needs fast retrieval	Cheaper storage; **30-day minimum**, **128 KB minimum billable size**, retrieval fee.
One Zone-IA	Re-creatable, infrequent data	Stored in **one AZ** only: cheaper, but lost if that AZ is lost.
Glacier Instant Retrieval	Archive read about once a quarter	Millisecond access; 90-day minimum.
Glacier Flexible Retrieval	Archive, retrieval in minutes to hours	90-day minimum.
Glacier Deep Archive	Long-term archive (7 to 10 years)	Cheapest; retrieval takes hours; 180-day minimum.

5. Lifecycle Rules

A lifecycle rule moves or deletes objects automatically, based on age.

- **Transition actions:** move objects to another storage class after N days (for example Standard to Standard-IA after 30 days, then to Glacier after 90).
- **Expiration actions:** delete objects after N days, delete old (noncurrent) versions, or clean up incomplete multipart uploads.
- Rules can apply to the whole bucket or to a prefix or tag. A common rule on a versioned bucket: permanently delete noncurrent versions after 30 days.

6. Static Website Hosting

- S3 can serve HTML, CSS, JavaScript and images directly: no server needed.
- Turn it on in **Properties** → **Static website hosting**, and set an **index document** (`index.html`) and an optional **error document**.

- The website endpoint is **HTTP only**, for example `http://BUCKET.s3-website.REGION.amazonaws.com`. For HTTPS and a custom domain, put **CloudFront** in front of the bucket (and Route 53 for the domain name).
- The content must be readable by visitors, which needs Block Public Access off **and** a public-read bucket policy, or CloudFront with Origin Access Control to a private bucket.

7. Hands-On Lab Recap: Host a Website from S3

1. **Create bucket:** unique name, Region eu-north-1. Untick Block all public access and acknowledge (this is a public website only).
2. **Upload** index.html and error.html.
3. **Properties** → **Static website hosting** → **Enable.** Index document index.html, error document error.html. Copy the website endpoint.
4. **Permissions** → **Bucket policy:** paste the public-read policy with your bucket name.
5. **Test** the endpoint over http://. A wrong path should show your error page.
6. **Versioning and lifecycle:** enable versioning, upload a changed file, view both versions, then add a rule to delete noncurrent versions after 30 days.
7. **Clean up:** empty the bucket, then delete it.

Troubleshooting

Symptom	Likely cause and fix
403 Forbidden on the website	Bucket policy missing, bucket name wrong in the policy, or Block Public Access still on. Turn it off first, then save the policy.
Browser downloads the file instead of showing it	You opened the normal object URL, not the **website endpoint** from the Properties tab.
AccessDenied when creating the bucket	Your IAM user lacks S3 permission. Attach an S3 policy to the user.
Cannot delete the bucket	It still holds objects (and versions). Empty it first, including old versions.

8. Cost Notes

- You pay for **storage** (per GB per month), **requests** (GET, PUT and so on) and **data transferred out** to the internet. Uploading data in is free.
- A small static website costs very little, but old versions, forgotten buckets and large transfers do add up. Check the AWS Free Tier page for the current free allowance on your account.
- Delete practice buckets when finished, and set a billing alert in AWS Budgets.

9. Interview-Style Questions

Question	Short answer
Why must bucket names be unique?	Bucket names share one global namespace across all AWS accounts and Regions.
How do you make an S3 bucket serve a public website?	Enable static website hosting, turn off Block Public Access, and add a public-read (s3:GetObject) bucket policy. Add CloudFront for HTTPS.
Bucket policy vs IAM policy?	IAM policies attach to identities; bucket policies attach to the bucket and can grant cross-account or public access.
How do you recover a deleted object?	If versioning was on, delete the delete marker (or restore an older version).
How do you cut storage cost for old data?	Lifecycle rules to move to IA or Glacier tiers, or Intelligent-Tiering for unknown patterns.
What does an explicit Deny do?	It overrides any Allow from any policy.

10. Quick Quiz

1. What makes an S3 bucket name different from most other AWS resource names?
2. True or false: new S3 buckets are public by default.
3. Which setting must you change, besides the bucket policy, to allow public website access?
4. What happens when you delete a file in a versioned bucket?
5. Which storage class is cheapest for a 10-year archive?
6. Why does the S3 website endpoint not use https?
7. A policy has an Allow in IAM but an explicit Deny in the bucket policy. What is the result?
8. What is the maximum size of one S3 object, and when must you use multi-part upload?

Answers

1) It must be globally unique. 2) False: everything is private by default. 3) Block Public Access (turn it off for that bucket). 4) A delete marker is added; older versions remain. 5) Glacier Deep Archive. 6) The S3 website endpoint supports HTTP only; use CloudFront for HTTPS. 7) Denied: explicit Deny wins. 8) 5 TB per object; multi-part upload is required above 5 GB (recommended above about 100 MB).